

BÀI THỰC HÀNH SỐ 4

Môn: MẬT MÃ & AN NINH MẠNG

-o0o-

I. MỤC TIÊU

- Cung cấp kiến thức về mã xác thực thông điệp MAC, tạo mã xác thực thông điệp sử dụng hàm hash (HMAC) sử dụng công cụ Cryptool.
- Cung cấp kiến thức về chữ ký số, demo các bước tạo chữ ký số trên thông điệp sử dụng công cụ Cryptool.

II. CHUẨN BỊ TRƯỚC KHI THỰC HIỆN BÀI THỰC HÀNH

- Sinh viên ôn tập lại phần lý thuyết chương 4 và chương 5
- Cài đặt công cụ Cryptool 1 (version: 1.4.31 Beta 06 - English), sinh viên có thể sử dụng công cụ Cryptool phiên bản mới hơn, giao diện tương tự. <https://www.cryptool.org/en/ct1-downloads>

III. CÁCH THỨC VÀ HẠN CHÓT NỘP BÀI

- Sinh viên trả lời tất cả các câu hỏi trong bài thực hành vào file <MSSV>_Lab04.docx (sử dụng mẫu file trả lời được đính kèm) và nộp bài theo deadline của bài Lab04 ở Bkel, không nhận bài nộp qua email hay các hình thức khác.
- Thời gian để thực hiện bài Lab là 14 ngày.

IV. NỘI DUNG THỰC HIỆN

Phần 1. Hệ mã bất đối xứng RSA

1.1. Tìm hiểu mã xác thực thông điệp MAC

Mã xác thực thông điệp, là một thông tin ngắn được sử dụng để xác thực một thông điệp, nói cách khác, mã xác thực thông điệp được sử dụng để xác nhận rằng tin nhắn đến từ người gửi đã nêu (tính xác thực) và không bị thay đổi (tính toàn vẹn).

Phân loại mã xác thực thông điệp:

- CMAC (hay CBC MAC): được tạo ra dựa trên thuật toán mã hoá đối xứng (AES và Triple-DES) theo chế độ CBC, dùng đầu ra của khối cuối như là MAC

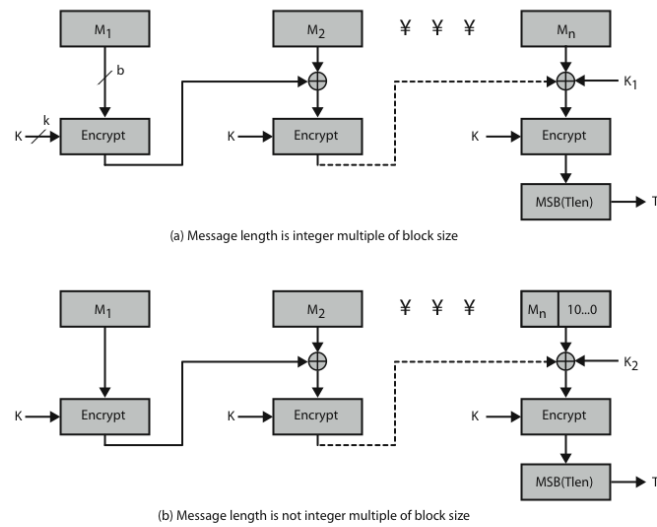
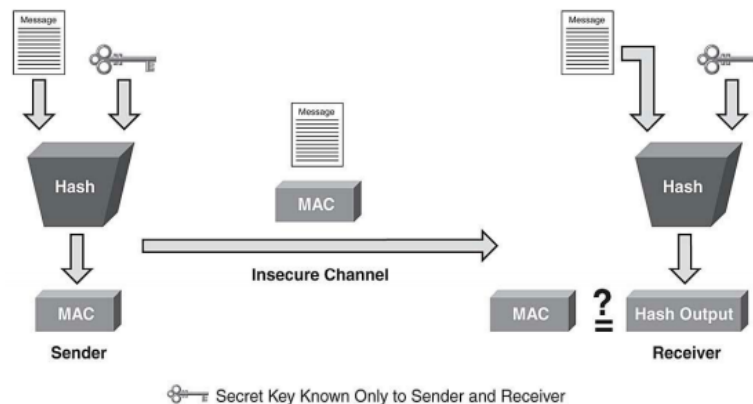


Figure 12.12 Cipher-Based Message Authentication Code (CMAC)

- HMAC (keyed-hash message authentication code): sử dụng hàm băm mật mã (hash) cùng với một khoá đối xứng



1.2. Bài tập

Câu 1. Sử dụng công cụ Cryptool để tính toán HMAC cho một thông điệp theo các bước như bên dưới:

Bước 1. Trong cửa sổ chương trình Cryptool, chọn menu **Indiv. Procedures** → **Hash** → **Generation of HMACs...**

Bước 2. Chọn hàm Hash tương ứng

Bước 3. Chọn biến thể HMAC (variant)

Bước 4. Nhập khoá (một hoặc nhiều khoá tùy theo biến thể HMAC đã chọn)

Bước 5. HMAC được tạo ra tự động sau khi nhập các thông số cần thiết



Bạn hãy sử dụng hướng dẫn như bên trên để thực hiện tính HMAC cho thông điệp và các thông tin bên dưới, ghi lại kết quả vào file trả lời và nhận xét về độ dài của các HMAC thu được:

Thông điệp:

Congrats on your tenth purchase! Enjoy a free cup of coffee and one pastry item on us by showing the cashier this text message!

Hàm Hash: Chọn các loại hàm hash: MD5, SHA-1, SHA-256, SHA-512

Biến thể (variant): Chọn tất cả biến thể có trong danh sách ứng với từng hàm hash lựa chọn ở trên.

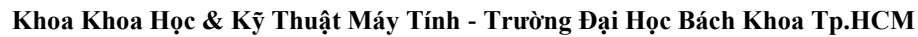
Nhập khoá:

k: tên đầy đủ của sinh viên viết liền (ví dụ: NguyenVanAn)

k' (nếu có): nhập mã số sinh viên

The screenshot shows the left window of the HMAC calculator. The message field contains the text: "Congrats on your tenth purchase! Enjoy a free cup of coffee and one pastry item on us by showing the cashier this text message!". The HMAC parameter and key section shows the hash function set to MD2 (128 bits) and the HMAC variant set to "HMAC key in front of message". The key field contains "NguyenTanTai". The inner hash value field is empty. The input for the outer hash function is "NguyenTanTai:Congrats on your tenth purchase! Enjoy a free cup of coffee and one pastry item on us by showing the cashier this text message!". The HMAC generated from message and key is displayed as "EA F6 33 AF BC 3A 1B E3 53 0D 4D 58 D4 EC 94 4B".

The screenshot shows the right window of the HMAC calculator. The message field contains the text: "Congrats on your tenth purchase! Enjoy a free cup of coffee and one pastry item on us by showing the cashier this text message!". The HMAC parameter and key section shows the hash function set to MD2 (128 bits) and the HMAC variant set to "HMAC key at the back of message". The key field contains "NguyenTanTai". The inner hash value field is empty. The input for the outer hash function is "Congrats on your tenth purchase! Enjoy a free cup of coffee and one pastry item on us by showing the cashier this text message!NguyenTanTai". The HMAC generated from message and key is displayed as "89 13 E5 74 93 A8 77 F5 A2 37 77 F6 94 E2 C7 B7".



Keyed-Hash Message Authentication Code (HMAC)

Description

By means of a HMAC the recipient of a message is able to verify its integrity and the authenticity of its sender. Therefore both parties use a shared secret (symmetric key).

To create a HMAC, a cryptographic hash function is applied to a combination of the message m and the secret key k. According to the variation chosen below, two different keys k₁ and k' can be used.

Message:

Congrats on your tenth purchase! Enjoy a free cup of coffee and one pastry item on us by showing the cashier this text message!

HMAC parameter and key

Hash function: [MD2(128 bits)] HMAC variant: [HK-m, k'] different keys

Enter your key (k): [NguyenTanTai]

Enter second key (k'): [221299[]]

Inner hash value:

[]

Input for outer hash function (depends on the HMAC variant chosen above)

NguyenTanTaiCongrats on your tenth purchase! Enjoy a free cup of coffee and one pastry item on us by showing the cashier this text message!
2212990

HMAC generated from message and key

7A C4 E8 EC 29 DA 86 50 D2 3B 4C 74 A0 B1 72 CF

Câu 2. Hãy liệt kê những hình thức tấn công dựa trên xác thực thông điệp?

Trang 4/10

Tấn công sửa đổi nội dung (Modification Attack): Kẻ tấn công chặn thông điệp trong quá trình truyền và thay đổi nội dung của nó. Nếu không có một MAC an toàn, người nhận sẽ không thể phát hiện ra sự thay đổi này.

Tấn công phát lại (Replay Attack): Kẻ tấn công chặn một thông điệp hợp lệ cùng với MAC của nó và gửi lại thông điệp đó để lừa người nhận thực hiện hành động ngoài ý muốn. Điều này đặc biệt nguy hiểm trong các hệ thống thanh toán hoặc xác thực.

Tấn công va chạm (Collision Attack): Kẻ tấn công cố gắng tìm hai thông điệp khác nhau nhưng có cùng một giá trị MAC, nhằm đánh lừa hệ thống rằng cả hai thông điệp là như nhau.

Tấn công dò tìm khóa (Key Recovery Attack): Đây là hình thức tấn công cố gắng tìm ra khóa bí mật được sử dụng để tạo MAC, từ đó cho phép kẻ tấn công giả mạo thông điệp một cách dễ dàng.

Câu 3. Trình bày sự khác nhau giữa mã xác thực thông điệp (MAC) và hàm băm (Hash)

Tiêu chí	Mã xác thực thông điệp (MAC)	Hàm băm (Hash)
Mục đích	Xác thực nguồn gốc và tính toàn vẹn của thông điệp	Xác thực tính toàn vẹn của thông điệp
Khóa	Sử dụng một khóa bí mật để tạo MAC	Không sử dụng khóa
Ứng dụng	Bảo mật trong truyền thông, chữ ký số	Tạo dấu vân tay của dữ liệu, lưu trữ mật khẩu
Khả năng chống tấn công	Bảo mật hơn do cần biết khóa bí mật để tạo và xác thực	Dễ bị tấn công giả mạo nếu không dùng thêm kỹ thuật bảo vệ khác
Cơ chế bảo mật	Yêu cầu khóa bí mật được chia sẻ giữa các bên	Tính một chiều (khó đảo ngược)

MAC sử dụng khóa bí mật: Khóa bí mật này giúp xác thực nguồn gốc thông điệp, vì chỉ những ai biết khóa mới có thể tạo hoặc xác thực MAC hợp lệ. Điều này bảo vệ thông điệp khỏi các tấn công mạo danh hoặc giả mạo.

Hàm băm không sử dụng khóa: Hàm băm là một hàm toán học một chiều, giúp tạo ra một giá trị băm (hash) cố định cho thông điệp. Giá trị hash chủ yếu được sử dụng để kiểm tra tính toàn vẹn của dữ liệu, nhưng không thể xác thực nguồn gốc vì không có yếu tố bảo mật.

⇒ MAC phù hợp cho các ứng dụng yêu cầu xác thực nguồn gốc và tính toàn vẹn của thông điệp nhờ vào việc sử dụng khóa bí mật, trong khi hàm băm chủ yếu dùng để kiểm tra tính toàn vẹn của dữ liệu mà không cần đến xác thực nguồn gốc.

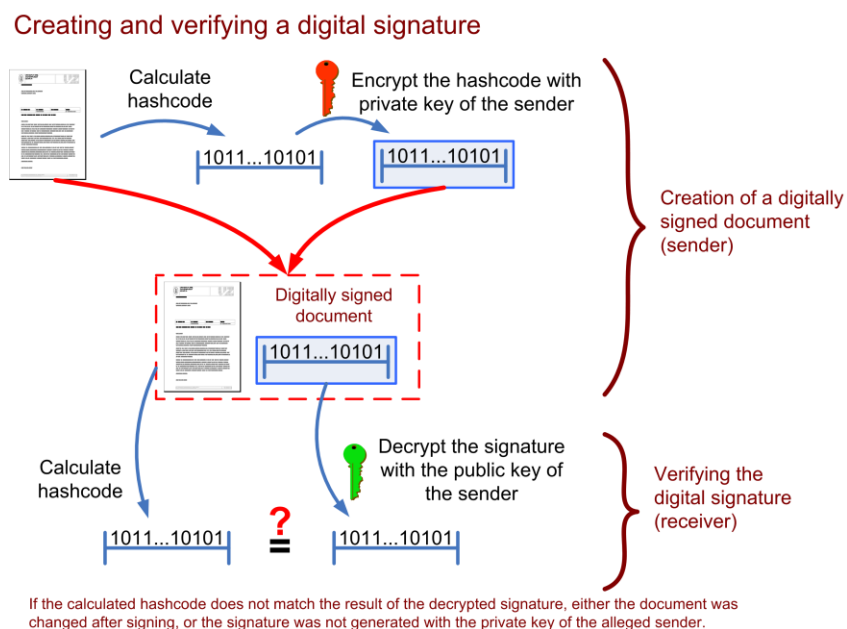
Phần 2. Chữ ký số

2.1. Tìm hiểu chữ ký số

Chữ ký số là một sơ đồ toán học để chứng minh tính xác thực của các thông điệp hoặc tài liệu kỹ thuật số, Chữ ký số cung cấp khả năng:

- Xác minh tác giả, ngày giờ đã ký (xác thực)
- Toàn vẹn thông điệp (toàn vẹn)
- Được xác minh bởi một tổ chức thứ 3 để giải quyết tranh chấp (chống thoái thác)

Chữ ký số được tạo ra theo sơ đồ như sau:



2.2. Bài tập

Câu 1. Mô phỏng chữ ký số bằng chương trình Cryptool, thực hiện theo các bước như hướng dẫn tham khảo bên dưới, với đầu vào là tập tin msg.txt chứa thông tên đầy đủ và mã số sinh viên. Chụp ảnh màn hình từng bước như phần tham khảo.

Ví dụ: sinh viên có tên Nguyễn Văn An và MSSV là 123456789, tập tin msg.txt có nội dung như sau:

Ten: Nguyen Van An
MSSV: 123456789
Lab 04 Digital Signature

Câu 2. Hãy cho biết các yêu cầu của chữ ký số?

Chữ ký số cần đáp ứng các yêu cầu quan trọng sau để đảm bảo tính bảo mật và hiệu quả:

Tính xác thực (Authentication): Chữ ký số phải xác minh được danh tính của người ký, đảm bảo rằng thông điệp hoặc tài liệu thực sự đến từ người tạo chữ ký.

Tính toàn vẹn (Integrity): Chữ ký số phải đảm bảo rằng thông điệp hoặc tài liệu không bị thay đổi sau khi được ký. Nếu có bất kỳ sự thay đổi nào, chữ ký sẽ không còn hợp lệ, giúp phát hiện các sửa đổi không mong muốn.

Chống thoái thác (Non-repudiation): Người ký không thể phủ nhận rằng mình đã ký tài liệu hoặc thông điệp. Điều này giúp ngăn chặn việc người gửi từ chối trách nhiệm về thông điệp mà họ đã ký.

Tính bảo mật (Confidentiality): Dữ liệu chữ ký và thông điệp phải được bảo mật trong quá trình truyền, tránh để lộ thông tin có thể bị khai thác.

Chữ ký số cần phải có các tính chất này để có thể sử dụng trong các giao dịch điện tử và liên lạc trực tuyến an toàn, giúp đảm bảo tính toàn vẹn, xác thực và trách nhiệm pháp lý cho các bên liên quan.

Câu 3. Hãy giải thích 2 tranh chấp có thể xảy ra khi sử dụng mã xác thực thông điệp MAC (người gửi thoái thác đã gửi thông điệp, người nhận thoái thác đã nhận thông điệp), chữ ký số giúp giải quyết vấn đề này như thế nào?

1. Các tranh chấp có thể xảy ra khi sử dụng MAC

Khi sử dụng Mã xác thực thông điệp (MAC), có thể xảy ra hai tranh chấp phổ biến sau:

Người gửi phủ nhận việc gửi thông điệp: Người gửi có thể thoái thác, phủ nhận rằng họ đã gửi thông điệp được xác thực bằng MAC. Điều này có thể xảy ra vì cả hai bên đều biết khóa bí mật dùng để tạo MAC, nên không thể chứng minh chắc chắn rằng chỉ có người gửi tạo ra thông điệp đó.

Người nhận phủ nhận việc nhận thông điệp: Người nhận có thể phủ nhận rằng họ đã nhận thông điệp và tuyên bố rằng họ chưa bao giờ nhận được nội dung đã gửi. Do cả

hai bên đều có thể tạo ra MAC, không có bằng chứng xác thực rằng người nhận đã nhận và kiểm tra thông điệp.

2. Chữ ký số giúp giải quyết vấn đề này như thế nào?

Chữ ký số khắc phục được các tranh chấp trên nhờ vào cơ chế sử dụng khóa công khai và khóa bí mật:

Chống phủ nhận từ phía người gửi: Chữ ký số được tạo bằng khóa bí mật của người gửi, và chỉ người gửi mới có thể tạo ra chữ ký đó. Khi chữ ký số được xác minh bằng khóa công khai của người gửi, nó cung cấp bằng chứng không thể phủ nhận rằng người gửi chính là tác giả của thông điệp. Điều này giúp ngăn chặn việc người gửi phủ nhận trách nhiệm sau khi gửi thông điệp.

Chống phủ nhận từ phía người nhận: Khi người nhận xác nhận tính hợp lệ của chữ ký số và chấp nhận thông điệp, việc này cũng được xem như bằng chứng rằng người nhận đã nhận thông điệp. Chữ ký số không thể bị tạo bởi người nhận, vì chỉ người gửi có khóa bí mật để ký. Điều này giúp người gửi có bằng chứng chống lại việc người nhận phủ nhận đã nhận thông điệp.